بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

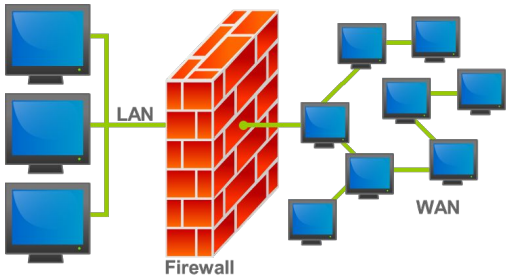
اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

Chapter 9

Firewalls

The Need For Firewalls



- Internet connectivity is essential
  - However it creates a threat
- Effective means of protecting LANs
- Inserted between the premises network and the Internet to establish a controlled link
  - Can be a single computer system or a set of two or more systems working together
- Used as a perimeter defense
  - **Single choke point to impose security and auditing**
  - Insulates the internal systems from external networks

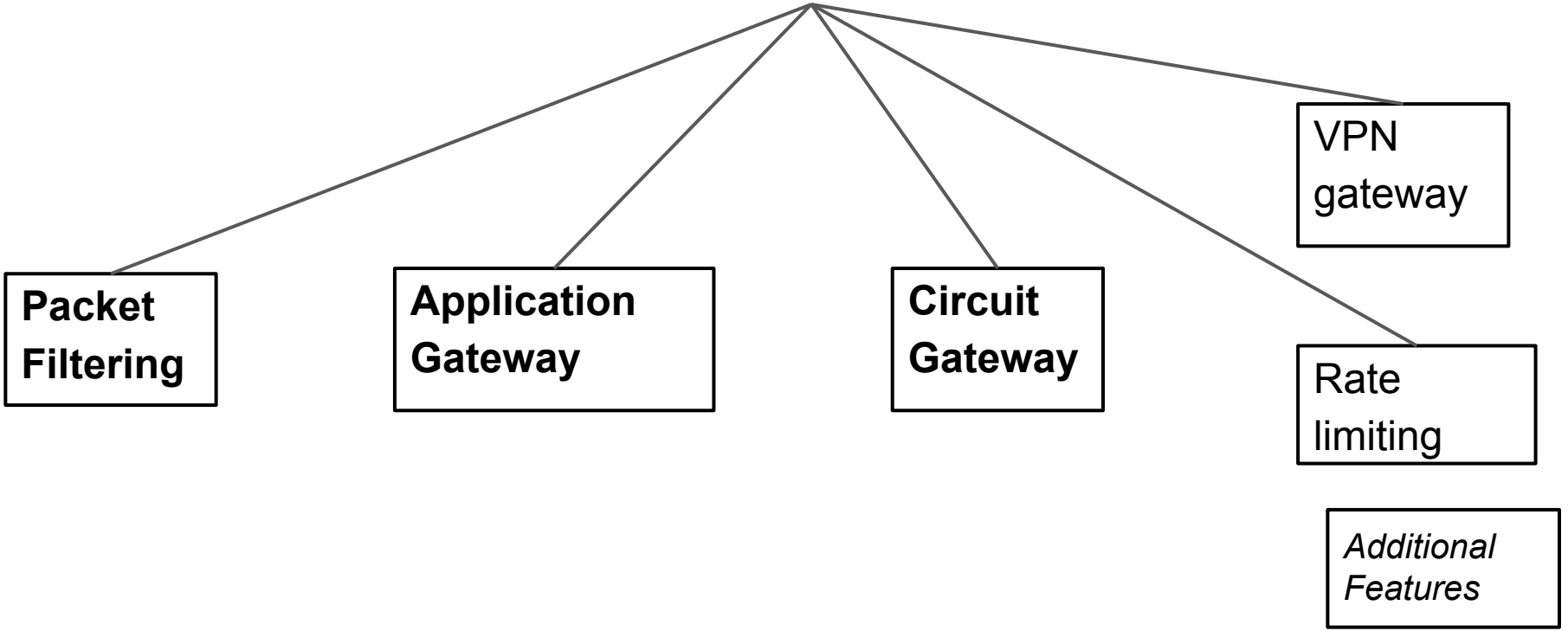
Firewall Characteristics

- All traffic from inside to outside, and vice versa, must pass through the firewall
- Only authorized traffic as defined by the local security policy will be allowed to pass
- The firewall itself is immune to penetration

Firewall Access Policy

- A critical component in the planning and implementation of a firewall is specifying a suitable access policy
  - This lists the types of traffic authorized to pass through the firewall
  - **Includes address ranges, protocols, applications and content types**
- This policy should be developed from the organization's information security risk assessment and policy
- **Should be developed from a broad specification of which traffic types the organization needs to support**
  - Then refined to detail the filter elements which can then be implemented within an appropriate firewall topology

Firewall Characteristics



Firewall Filter Characteristics

Characteristics that a firewall access policy could use to filter traffic include:

IP address and protocol values

This type of filtering is used by **packet filter and stateful inspection firewalls**

Typically used to limit access to specific services

Application protocol

This type of filtering is used by an **application-level gateway** that relays and monitors the exchange of information for specific application protocols

User identity

Typically for **inside users** who identify themselves using some form of secure **authentication technology e.g VPNs (IPSec)**

Network activity

Controls access based on considerations such as the **time or request, rate of requests, or other activity patterns**

Packet Filtering Firewall

- Applies rules to each incoming and outgoing IP packet
  - Typically **a list of rules based on matches in the IP or TCP header**
  - **Forwards or discards the packet based on rules match**

Filtering rules are based on information contained in a network packet
• Source and Destination IP address • Source and destination transport-level address (ports) • IP protocol field (e.g. TCP/UDP/ICMP etc) • Interface • Direction (inbound/outbound)

- Two default policies:
  - **Discard** - prohibit unless expressly permitted: More conservative control
  - **Forward** - permit unless expressly prohibited: Easier to manage but less secure

Packet-Filtering Examples

Rule	Direction	Src address	Dest addresss	Protocol	Dest port	Action
1	In	External	Internal	TCP	25	Permit
2	Out	Internal	External	TCP	>1023	Permit
3	Out	Internal	External	TCP	25	Permit
4	In	External	Internal	TCP	>1023	Permit
5	Either	Any	Any	Any	Any	Deny

Transport layer Ports (0-65535)

65535 = $2^{16}-1$

Well-Known Ports (0 – 1023)

- Used by system or widely known services (HTTP 80, HTTPS 443, SSH 22, DNS 53).

Registered Ports (1024 – 49151)

- Assigned to specific applications/vendors (e.g. MySQL 3306, MS SQL 1433).

Private Ports (49152 – 65535)

- Not assigned; typically chosen automatically and randomly by client machines as **source ports** for outbound connections.

What about filtering of packets coming back to the **randomly selected source ports** (in the higher private range)? **Have to be allowed by default for being unpredictable**

Stateful Firewall

- A stateful inspection packet firewall **creates a directory of outbound TCP connections.**

- The packet filter will **now allow incoming traffic to high-numbered ports only for those packets that fit the profile of one of the entries in this directory**.

- A stateful packet inspection firewall **reviews the same packet information as a packet filtering firewall, but also records** information about TCP connection

Stateful Inspection Firewall

Tightens rules for TCP traffic by creating a **directory of outbound TCP connections**

- There is an **entry for each currently established connection**
- Packet filter **allows incoming traffic to high numbered ports only for those packets that fit the profile of one of the entries in this directory**

Reviews packet information but also records information about TCP connections

- Keeps track of TCP sequence numbers to prevent attacks that depend on the sequence number
- Inspects data for protocols like FTP, IM and SIPS commands

Example Stateful Firewall

Connection State Table

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.9.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
219.22.123.32	2112	192.168.1.6	80	Established
210.99.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.21.22.12	1046	192.168.1.6	80	Established

Application-Level Gateway

- Also called an **application proxy** (relay of application-level traffic) for a particular application or protocol e.g. SIP
  - User contacts gateway using a TCP/IP application
  - User is **authenticated**
  - Gateway contacts application on remote host and relays TCP segments between server and user
- **Must configure proxy support** for each application for the application to work
- **More secure than packet filters** as needs scrutinize only a few allowable applications.
- Can be configured to **support only specific (secure) features** of application
- Disadvantage is the **additional processing** overhead on each connection

Circuit-Level Gateway

Circuit level proxy

- Sets up two TCP connections, one between itself and a TCP user on an inner host and one on an outside host
- **Relays TCP segments from one connection to the other without examining contents**
- Security function consists of determining which connections will be allowed

Typically used when inside users are trusted

- **May use application-level gateway inbound and circuit-level gateway outbound**
- Lower overheads

VPN gateway

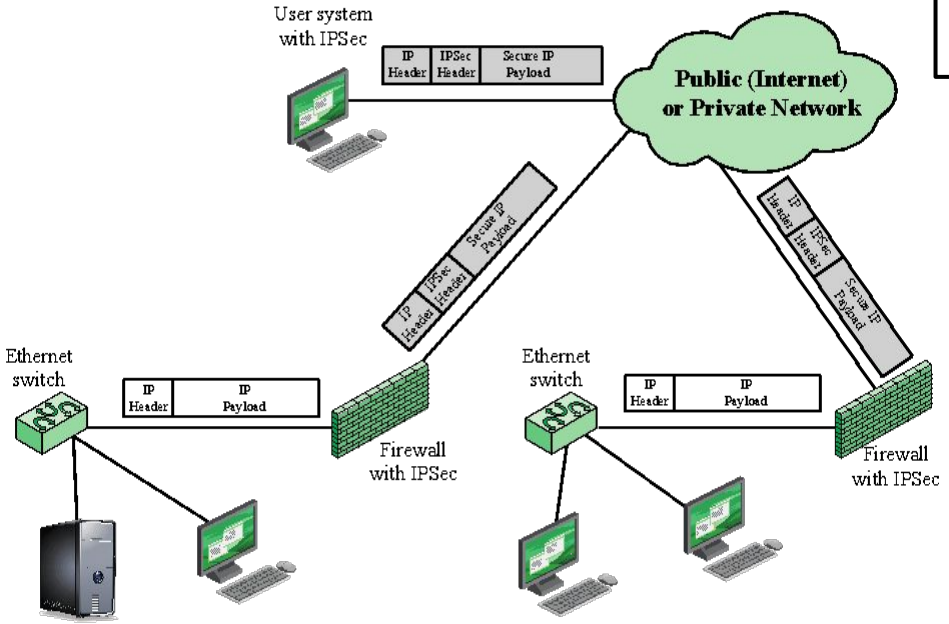
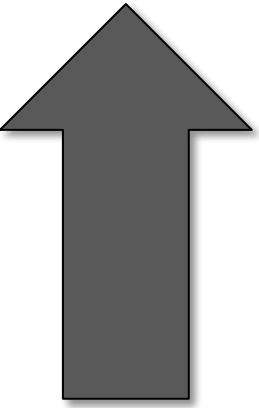


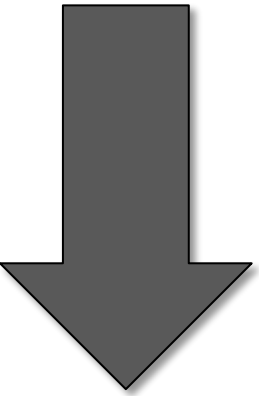
Figure 9.3 A VPN Security Scenario

Firewall Capabilities And Limits



Capabilities:

- **Defines a single choke point**
- **Provides a location for monitoring security events**
- **Convenient platform for several Internet functions that are not security related**
- **Can serve as the platform for IPSec**



Limitations:

- **Cannot protect against attacks bypassing firewall**
- **May not protect fully against internal threats**
- **Improperly secured wireless LAN can be accessed from outside the organization**
- **Laptop, PDA, or portable storage device may be infected outside the corporate network then used internally**

Firewall Activity (ICMP)

In groups of 2, use one machine to ping another (4 small packets, 32 B) while running Wireshark with the appropriate filters: [`icmp / icmp.type==8` (Echo Request) and `icmp.type==0` (Echo Reply)]

1) On the target disable inbound ICMP. Observe only requests with no replies.

- Windows: block ICMPv4 rule;
- Linux: `iptables -A INPUT -p icmp --icmp-type echo-request -j DROP`),

2) Then enable ICMP, repeat the pings, and observe both request/reply pairs.

3) Instead of blocking ICMP globally, allow ICMP but block only the *source IP* of the pinger on the target. Observe

- Windows: firewall rule with `-RemoteAddress`;
- Linux: `iptables -A INPUT -s <source_IP> -p icmp --icmp-type echo-request -j DROP`)